ID: SECURITY-POL00029-STN00020
Driver: Nidhi Bandi
Classification: Internal
Version: 10.0

Vendor Information Security Standard

1. Overview

This standard defines the security requirements related to management of products and services procured from vendors.

2. Scope

This Standard applies to all Adobe Vendors, Vendor Security Team, and Business Owners (Relationship Manager) interacting with the vendors.

Vendor Security Team: The team that conducts the vendor security reviews (initial or re-assessment) for Adobe's vendors and determine their security risk.

Business Owner (Relationship Manager): The person responsible for the relationship with the Vendor and the product or item being procured or used. The overarching Vendor Risk Management Policy includes comprehensive responsibilities of a Business Owner.

Vendor: The third party that is receiving funds for goods and/or services that will be provided to Adobe. Please refer to Vendor Risk Management Policy, for additional details.

This Standard does not apply to onsite vendor workers or remote vendor workers, who are governed by the Master Services Agreement (with their employer) as detailed on the Contingent Workforce Program page.

3. Statement

Vendor and vendor provided services must be reviewed and approved in accordance with the criteria defined in the Vendor Risk Management Policy, prior to allowing any third party to interact with Adobe or its customer's environment or data. The data classification and business use-case must determine what reviews are required, including, but not limited to:

- Vendor Security Review, managed by the Security team
- Vendor Privacy Assessment, managed by Privacy Office and Cybersecurity Legal team (POCL)

3.1. Vendor Security Team

3.1.1. Vendor Security Team reviews the security posture of the products and services being procured from the vendor for use at Adobe and assigns a security risk rating to the vendor.

3.1.2. For vendors with high risk, Vendor Security Team's assessment must comprise security risks and recommendations including risk mitigation and remediation actions, where needed.

3.1.3. Vendors rejected during vendor security review, due to high risk, are escalated to Third Party Risk Management Office (TRPM) to work with business for appropriate risk treatment (e.g. risk acceptance, risk mitigation, and/or offboarding).

Contents

1. Overview
2. Scope
3. Statement
   3.1. Vendor Security Team
   3.2. Business Owner (Relationship Manager)
   3.3. Vendor Security Review (VSR)
   3.4. Additional Requirements
   3.5. Requirements Specific to Cardholder Data Environments
   3.6. Requirements Specific to ePHI Environments
   3.7. Requirements Specific to FedRAMP Environments
4. Definitions
5. Other Stakeholders and Responsibilities
6. Governing Policy
7. References
8. Document Properties
9. Document History

3.1.4. Either Vendor Security team or POCL team must indicate the need to include Vendor Data Processing and Transfer Agreement (VDPTA) and Information Security Terms in vendor contracts during vendor security review, where required.

3.2. Business Owner (Relationship Manager)

3.2.1. Business Owners must follow the onboarding and re-assessment process mentioned in Vendor Risk Management Policy to trigger the Vendor Security Review (VSR) process.

3.2.2. The Business Owner must review and update the vendor use case every 1 – 3 years based on the risk rating or in case of change in use case.

3.2.3. The Business Owner must provide accurate information during onboarding and re-assessment phase, to reflect the current use case/purpose of the vendor services, exact service being procured/used (technology/service), as well as the data and network access involved (access, store, process, or otherwise engage) for the vendor.

3.2.4. Risks, mitigations and remediations recommended during the vendor security review must be reviewed carefully by the Business Owner and be adhered to within suggested timelines by the Business Owner and the vendor.

3.2.5. If the business decides to work with a High risk vendor (identified during Vendor Security Review), the Business Owner and their management (Director or higher) must review and accept the risk.

3.2.6. Business Owner must abide by Adobe Technology Standards, during interaction (while sharing data with vendor, integrating vendor services to Adobe, terminating vendor services, etc.) with the vendor or vendor services, throughout the vendor lifecycle.

3.2.7. Business Owner must work with the vendors to complete/update the security and privacy assessment (Supplier Security/Privacy Questionnaire) at the time of onboarding and re-assessment, for each service procured from the vendor.

3.3. Vendor Security Review (VSR)

3.3.1. Vendor Security Review (VSR) must be performed during initial vendor onboarding and a risk rating must be assigned.

3.3.2. Vendors must be periodically re-assessed every 1 – 3 years based on the risk rating (High – 1 year, Medium – 2 years, Low – 3 years).

3.3.3. A manual or automated review must be performed based on inherent risk (such as services provided by the vendor, need for access to Adobe data or environment) of the vendor.

3.3.4. Adobe expects vendors to use and secure Adobe data and network per Adobe security and privacy standards. Below is a list of risk areas assessed during vendor security review. It is not an exhaustive list but a guardrail for VSR. Please refer to the Vendor Security Guidance wiki for requirements for each area.

- Information Security policies and program
- Application Security
- Vulnerability and Patch Management
- Logging and Monitoring
- Authentication
- Access Control
- Device Posture / Endpoint Security
- Network Security
- Data Handling and Sharing
- Data Encryption
- Artificial Intelligence Security
- Third Party Risk Management
- Physical Access
- Breach Notification
- Business Continuity
- Service and Data Decommissioning
- Security Certification or Attestation by third parties (SOC2, PCI, ISO27001, Pentest reports, etc.)
- Threat Intelligence

3.4. Additional Requirements

3.4.1. Information Security and Privacy terms, including security incident-related obligations as applicable, must be included in the vendor contract designed to protect the security, confidentiality and integrity of Adobe's systems and data as appropriate in the context of vendor engagement.

3.4.2. When Adobe workers become aware of a vendor that has not had their security previously assessed, an assessment must be started within 30 days. If a security review cannot be completed because of a lack of 'timely' engagement by Adobe Business Owner or the vendor then the vendor

may move to a non-approved status or otherwise be blocked by technical means for new business until either (a) an assessment is completed or (b) a formal exception has been documented, reviewed, and approved by TRPM.

3.4.3. Per the Travel and Expense Policy, unless you have been granted an exception, Adobe prohibits the purchase of any services outside of the procurement system in which the vendor processes or stores Confidential or Restricted Data (for example, employees must not use an expense card to pay for a SaaS vendor that processes Confidential data).

3.5. Requirements Specific to Cardholder Data Environments

In addition to all the above requirements of this standard, the following requirements must be met for vendors that process, store, or access Cardholder Data. For more requirements specific to Cardholder Data, refer to the Cardholder Data Protection Standard.

3.5.1. Vendors must produce an auditable record of current Payment Card Industry Data Security Standards (PCI DSS) compliance during onboarding and annually thereafter, in the form of a Qualified Security Assessor (QSA)-signed Attestation of Compliance (AOC) or Report on Compliance (ROC). These requirements must be explicitly agreed to in the InfoSec and Privacy terms.

3.5.2. Vendor and Business Owner must develop an auditable responsibility matrix outlining who is responsible for which PCI requirements before doing business.

3.5.3. The vendor must agree to cooperate with Adobe's investigation as part of the Data Processing Agreement (VDPTA)/InfoSec terms.

3.5.4. Vendors that manage, store, or transmit cardholder data (as defined by PCI DSS) must provide written acknowledgement to Adobe of their responsibility to protect cardholder data and the cardholder data environment in accordance with the applicable Data Processing Agreement/Information Security and Privacy terms.

3.6. Requirements Specific to ePHI Environments

In addition to all the above requirements of this Standard, the following requirements must be met for environments that process, store, or access ePHI:

3.6.1. A vendor service provider that accesses, collects, transmits, processes, or stores protected health information (PHI) or electronically protected health information (ePHI), is required to enter into a Business Associate Subcontractor Agreement (BASA) that has been reviewed, approved, and retained by the POCL.

3.6.2. Vendor Business Associate Subcontractor Agreement (BASA) that involves vendor access to Protected Health Information (PHI) must contain language required by the HIPAA Security Rule and/or Privacy Rule:

- Permitted Uses and Disclosures of PHI
- Safeguards to Prevent Unauthorized Use or Disclosure of PHI
- Communications regarding the Unauthorized Use or Disclosure of PHI
- Availability of PHI
- Contract Termination and Disposition of all PHI

3.7. Requirements Specific to FedRAMP Environments

Refer to the FedRAMP Environment Protection Standard for requirements specific to FedRAMP environments.

4. Definitions

Term	Definitions
Payment Card Industry Data Security Standard (PCI DSS)	Proprietary information security standard for organizations that handle branded credit cards from the major card schemes including Visa, MasterCard, American Express, Discover, and JCB.
POCL	Privacy Office and Cybersecurity Legal team
Process or Processing	Refer to Data Classification and Handling Standard.
Qualified Security Assessor (QSA)	Refer to PCI DSS

Term	Definitions
Vendor	Third parties that interact with Adobe information or information systems in some form. These may be supplied, outsourced, contracted, or temporary third parties.
Business Owner (Relationship Manager)	Refer to Vendor Risk Management Policy.
VDPTA	Vendor Data Processing and Transfer Agreement
Vendor Security Review (VSR)	A risk assessment for a vendor that collects, stores, processes, transmits, or disposes of Adobe Internal, Confidential, or Restricted data outside of Adobe-controlled physical office or data center locations.

5. Other Stakeholders and Responsibilities

Group	Responsibilities
Global Procurement	• Maintain Vendor Master Information (VMI) database for all Adobe vendors who require a Purchase Requisition. • Maintain links between VMI database and legal contracts related to vendors. • Maintain a process to request a Vendor Security Review according to the requirements of this Standard. • Coordinate annual Strategic Business Reviews (SBRs) for strategic vendors.
IT VMO (Vendor Management Office)	• Maintain list of all current IT Vendors based on Procurement VMI Database. • Maintain supplemental information on current Business Owners. • Request annual information updates from Business Owners. • Participate in annual Strategic Business Reviews (SBRs) for Strategic IT vendors.
POCL	• Draft and maintain Information Security & Privacy Exhibit, which is attached to vendor contracts for vendors that process or store Adobe Restricted data, Confidential data or data that contains personal information (PI) regardless of classification on Adobe's behalf. • Perform Vendor Privacy Assessment for a vendor who accesses, transfers, processes, or stores personal information (identified as part of data classification).
Procurement Legal	• Maintain records of all contracts with vendors. • Review vendor agreements as required by approval workflows, or by request of authorized Adobe personnel.
Third Party Risk Management Office (TRPM)	• Team responsible for implementing consistent risk management practices. partners with various groups within Adobe, including but not limited to procurement, legal, business resilience, Information security, privacy, and ethics & compliance to implement a global and effective enterprise-wide vendor risk management ecosystem.

6. Governing Policy

Adherence to the governing Policies referenced below is required to be compliant with this Standard:

- Information Security Policy
- Vendor Risk Management Policy

7. References

The following referenced documents can be found on the Technology Policies and Standards Inside Adobe site:

- Data Classification and Handling Standard

- FedRAMP Environment Protection Standard
- Travel and Expense Policy

8. Document Properties

Coordinator	Ensures Review, Approval and Publication; Facilitates Discussions	Anastasia Conti (Manager, Governance, Tech GRC)
Driver	Subject Matter Expert; Owner of Content; Works with Contributors	Nidhi Bandi (Manager, Vendor Security)
Approver	Approves Document; Ultimately Responsible for Execution	Sangeeta Arora (Director, Vulnerability Management) Bryan Payne (Vice President of Product and Software Security

9. Document History

Version	Approval Date	Changes	Approved By
9.0	October 2024	Major Changes • Restructured the whole document to clearly outline responsibilities based on worker type Minor Changes • Section 3.3.1 – Updated the name of 'Information Security Incident Response Standard' • Removed sections related to 'Exceptions' and 'Violations' • Section 8 & 9 – Added descriptions for all standards and policies referenced within the standard	Sangeeta Arora, Director, Vulnerability Management Bryan Payne, Vice President of Product and Software Security
10.0	September 2025	No Major Changes Minor Changes • Throughout the document, Vendor Risk Management Office (VRMO) updated to Third Party Risk Management (TRPM) • Section 7 – Added references to FedRAMP Environment Protection Standard and Data Classification Standard	Sangeeta Arora, Director, Vulnerability Management Bryan Payne, Vice President of Product and Software Security

Signature: Sangeeta Arora (Sep 22, 2025 14:37:00 PDT)
Email: smishra@adobe.com

Signature: Bryan Payne (Oct 1, 2025 12:44:00 PDT)
Email: bryanp@adobe.com